



Government
Digital Service



Department for
Science, Innovation
& Technology

Aligning AWS Threat Composer with Secure by Design

October 2025

Contents

Background	4
Purpose	4
Secure by Design on the UK Government Security website	4
AWS Threat Composer	5
1. Key concepts and terminology	5
2. Architecture and components	6
3. Threat composer implementation	6
4. Writing threat models: Grammar and templates	7
5. Threat visualisation and editing	7
6. Automating threat detection	8
7. Integration with AWS services and ecosystem	8
8. Best practices and governance	9
More information	9

Background

In today's rapidly-evolving digital landscape, cloud-native architectures and distributed systems introduce new opportunities, but also new risks. The complexity of these environments demands that security considerations are integrated from the outset, rather than bolted on afterwards.

[AWS Threat Composer](#), an open-source threat modeling tool, supports this philosophy by providing a structured method for identifying and mitigating potential threats throughout the design and delivery process.

The [Secure by Design](#) approach is a government framework which embeds cyber security into digital services from the outset. Its goal is to make security an integral, proactive part of all government digital systems, rather than an afterthought.

Threat Composer can help you meet [Secure by Design principles](#) thanks to:

- schema-based modeling
- automation capabilities
- integration with the AWS ecosystem

Through Threat Composer, organisations can visualise system components, assess risk exposure and document mitigations in a format that's repeatable and auditable. This helps teams:

- enhance their technical understanding
- improve governance processes
- show they're working within the Secure by Design framework
- show they're meeting other regulatory expectations

Purpose

The purpose of this document is to align AWS Threat Composer with the government's Secure by Design principles.

Integrating the Secure by Design approach into Threat Composer strengthens security from the earliest stages of system development. It does this by embedding structured, risk-driven threat modelling into design processes. It helps government organisations to:

- proactively identify and prioritise risks
- define effective mitigations
- maintain continuous assurance as systems evolve

Secure by Design on the UK Government Security website

- [Secure by Design policy](#)
- [Implementing Secure by Design](#)
- [Guide to adopting Secure by Design](#)

AWS Threat Composer

Threat modeling is a proactive and structured approach to identifying, analysing and mitigating potential vulnerabilities before they can be exploited.

AWS Threat Composer is an open-source tool that simplifies the creation, documentation and management of threat models. Reflecting Secure by Design principle 2, Source secure technology products, Threat Composer helps teams to evaluate and document the security posture of both internal systems and third-party services before they are integrated into the environment.

In keeping with Secure by Design principle 1, Create responsibility for cyber security risk, Threat Composer helps embed accountability into every stage of system design and delivery. By making the identification of risk a shared task across development, operations and leadership teams, it transforms security from an afterthought into a fundamental business responsibility. And by integrating threat models into source control systems, organisations can keep security decisions transparent and traceable.

Threat Composer helps identify and evaluate dependencies early in the design process. This approach mitigates supply chain risks and provides visibility into the origin and security posture of third-party services. Being able to attach mitigation and remediation evidence encourages due diligence and proper vendor assurance.

Threat Composer's open-source design gives it transparency. Because it is a community-driven platform, organisations can validate the integrity of code, reduce vendor lock-in and benefit from enhancements that have been peer reviewed.

Because it allows extensions, Threat Composer can be integrated with vulnerability scanning tools and supplier assurance platforms, aligning it with the Secure by Design activity [Managing observability](#). This means that vendor assessments and security certifications can be automatically updated within threat models, keeping products continuously secure.

The NCSC has more information on threat modelling as part of its [Building a Security Operations Centre \(SOC\) guidance](#).

1. Key concepts and terminology

AWS Threat Composer is built around a structured, risk-oriented modeling approach that prioritises security decisions based on impact and likelihood. In keeping with Secure by Design principle 3: Adopt a risk-driven approach, every identified threat, mitigation and control can be evaluated against measurable business objectives. This allows organisations to allocate resources to where they matter most.

Integrating risk prioritisation into Continuous Integration and Continuous Delivery (CI/CD) workflows means that every build or release can be automatically evaluated against the

risk tolerance levels of an organisation. This turns security governance into a measurable, continuous activity that scales with development.

The tool's flexibility allows it to be integrated with established risk management frameworks like the Common Vulnerability Scoring System (CVSS). Linking Threat Composer to external frameworks makes sure decision-making is:

- evidence-based
- strategic
- aligned with the organisation's wider risk posture

2. Architecture and components

AWS Threat Composer helps design security architectures that are practical, effective and usable, supporting Secure by Design principle 4: Design usable security controls. The platform lets teams create and document mitigations that protect systems and align with user needs. This makes sure that controls are intuitive and easy to implement.

Incorporating user feedback into threat model reviews helps refine the way controls are designed. When developers and users work together to identify friction points, controls can be adjusted to improve user experience.

Additionally, using performance metrics and user behaviour analytics helps confirm that controls are working as expected in real-world conditions.

You can document feedback within Threat Composer, which allows you to track how your organisation has improved controls over time. As organisations evolve, these records can help keep controls effective and practical.

3. Threat composer implementation

Implementing AWS Threat Composer from the outset helps teams integrate detection and response mechanisms directly into their system design. This aligns with Secure by Design principle 5: Build in detect and respond security.

When monitoring points, logging strategies and response triggers are embedded in the design phase, threats can be detected and addressed before causing significant damage.

By mapping monitoring requirements to specific components, Threat Composer promotes structured observability and rapid incident response.

By linking detection and response strategies to operational playbooks you can make sure there's alignment between engineering and security operations teams. This creates a unified approach to threat response, reducing mean time to detect (MTTD) and mean time to respond (MTTR).

Additionally, using automation to trigger security checks from Threat Composer's outputs allows you to continuously validate your detection coverage. This dynamic feedback strengthens the prevention and response layers of the organisation's security posture.

Finally, integrating threat modeling outputs with Security Information and Event Management (SIEM) systems aligns the detection logic modeled in Threat Composer with live monitoring environments. This helps provide a complete view of detection maturity.

4. Writing threat models: Grammar and templates

Designing systems that can adapt securely to change is central to Secure by Design principle 6: Design flexible architectures. AWS Threat Composer supports this by offering modular, reusable threat modeling structures. Its schema-based design means that as systems evolve, their corresponding threat models evolve with them, and security coverage is continuous.

Creating modular models encourages consistency and reduces redundancy. When a component or service is reused across multiple systems, you can import and tailor its threat model.

This flexibility also extends to how threat models integrate with automated systems. Because Threat Composer uses machine-readable schema, it can apply updates as systems change, so threat coverage is aligned with the latest architecture.

Being flexible improves long-term resilience. By documenting expected security properties and interfaces, organisations can adapt more rapidly to new technologies such as AI or container orchestration without compromising the integrity of their security architecture.

This adaptability future proofs threat modeling. As new regulatory requirements or technologies emerge, flexible models allow organisations to adjust swiftly, balancing innovation with robust security assurance.

5. Threat visualisation and editing

Reducing unnecessary complexity and exposure is at the heart of Secure by Design principle 7: Minimise the attack surface. AWS Threat Composer supports this by helping teams visualise and streamline their architectures directly within Visual Studio Code. Through clear and interactive diagrams, teams can identify elements that may increase an attack surface, like:

- redundant components
- excessive privileges
- insecure communication paths

The interactive interface allows developers and architects to easily map components, connections and data exchanges. This makes it easier to detect over-permissioned roles or unneeded APIs that expand the attack surface. By removing or restricting such elements, organisations can keep their architecture lean and purposeful.

Integrating visual threat models with CI/CD pipelines adds automated validation. You can set configuration rules to flag insecure patterns like overly broad Identity and Access Management (IAM) permissions or exposed storage buckets before deployment. This

helps enforce the principle of least privilege and make sure there are security checks continuously throughout development.

6. Automating threat detection

Creating multiple, overlapping layers of protection is essential to meet Secure by Design principle 8: Defend in depth. AWS Threat Composer helps organisations implement this by embedding threat awareness and monitoring into every layer of their cloud architecture.

The layered security controls include network, infrastructure and organisational process controls. By integrating threat modeling into build pipelines and runtime monitoring, Threat Composer ensures that each defence mechanism supports and reinforces the others.

Automating threat assessments during the build and deployment phases means vulnerabilities can be detected earlier in the development life cycle. When connected to tools such as [AWS Security Hub](#), [Inspector](#) or [GuardDuty](#), Threat Composer models can check whether known threats are being actively monitored in production environments.

Automated responses strengthen operational resilience. Security events detected by runtime tools can trigger updates to threat models, so the documentation remains dynamic and relevant. This creates a continuous feedback loop that improves the accuracy of detection and how efficient the response is.

Adding periodic validation tests for layered defences makes sure mechanisms function as intended in real-world conditions. Doing this is a good way of confirming that multiple security layers complement each other rather than overlap.

7. Integration with AWS services and ecosystem

Carrying out ongoing validation of security controls is key to Secure by Design principle 9: Embed continuous assurance. AWS Threat Composer facilitates this by connecting to AWS-native monitoring and compliance services. By continuously verifying that mitigations are working as intended, organisations maintain visibility and confidence in their security posture.

This integration allows teams to validate that the mitigations they've modeled have been correctly implemented and are working as expected. For example, automated checks can confirm encryption status, IAM restrictions or logging configurations based on established baselines. Any deviation from these expected states can trigger alerts.

Continuous assurance is also good for compliance management. You can link Threat Composer models with evidence repositories and compliance dashboards to provide auditable proof that operations are secure.

For even more efficient reporting, Threat Composer can auto-generate assurance reports, consolidating data from multiple AWS accounts into a single overview.

By embedding continuous assurance, you can foster a proactive security culture. Doing so empowers teams to:

- anticipate compliance gaps
- respond quickly to changes
- stay aligned with internal policies and external standards

8. Best practices and governance

Maintaining strong security as systems change and evolve is an essential part of Secure by Design principle 10: Make changes securely. AWS Threat Composer helps embed this discipline by making sure every change in architecture or infrastructure includes a security review. This approach transforms change management from a procedural task into an embedded element of secure design.

Threat Composer's version control means each change in infrastructure or code triggers a traceable security validation. This process embeds secure change management directly into development workflows, making misconfigurations or unassessed risks less likely to reach production.

By establishing governance frameworks for change control, you can make sure security remains consistent and verifiable. Approvals, peer reviews and automated scans driven by Threat Composer outputs help align operational changes with governance standards and organisational policies.

When there's collaboration across functions, you can enhance security resilience even more. If developers, security architects and compliance teams all assess proposed changes, ownership of risk is shared and it's clear who's accountable.

Threat Composer exemplifies the Secure by Design mindset by embedding accountability, automation and adaptability throughout the system life cycle. Through disciplined governance, continuous validation and secure change management, government organisations can innovate confidently while maintaining strong alignment with Secure by Design principles.

More information

- [Secure by Design Principles \(UK Government Security\)](#)
- [Secure by Design Activities \(UK Government Security\)](#)
- [AWS Toolkit for Visual Studio Code: Working with Threat Composer \(AWS Documentation\)](#)
- [Threat modelling \(NCSC.GOV.UK\)](#)